



University of Antwerp
| Faculty of Science

Computer and Network Security (2026-2027)

Part 1: Introduction

Jeroen Famaey

jeroen.famaey@uantwerpen.be

- 1 Course goals
- 2 Practical course arrangements
- 3 Basic security concepts

Course objectives

- Understand and use cryptographic algorithms
- Understand and identify security flaws in cryptographic algorithms
- Design and develop secure (distributed) software applications
- Configure and deploy secure computer network protocols and policies

Security is everywhere

- **Secure communication**

- Web traffic: HTTPS using Transport Layer Security (TLS/SSL)
- Secure Shell (SSH)
- Internet Protocol Security (IPsec)
- Wireless traffic: 802.11i WPA2 (and WEP), GSM, Bluetooth, ...

- **Encryption of stored data**

- On disk: Encrypted File System (EFS), TrueCrypt
- Secure password storage
- Content protection
 - DVD: Content Scramble System (CSS)
 - Blu-ray: Advanced Access Content System (AACS)

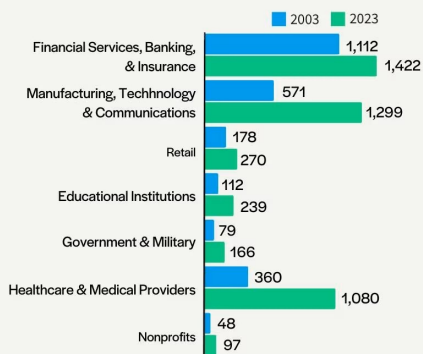
- **User authentication:**

- OAuth2
- Extensible Authentication Protocol (EAP)

- **... and much more**

Data Breach Statistics

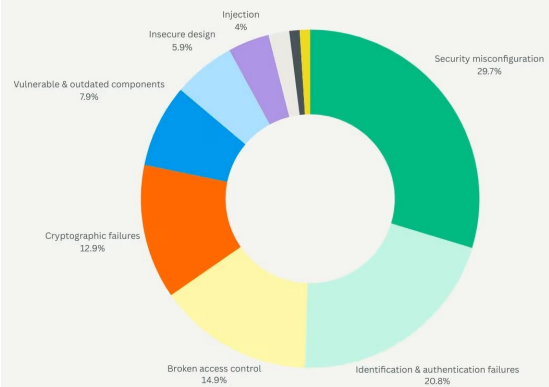
Number of data breaches
by industry



Source: Privacy Rights Clearinghouse, 2023

secureframe

Top OWASP Web Application
Security Risks



Source: IBM X-Force Threat Intelligence Index 2024

secureframe

Uber data breach (September 2022)

The New York Times

Uber Investigating Breach of Its Computer Systems

The company said on Thursday that it was looking into the scope of the apparent hack.

Give this article



A message on Uber's internal system on Thursday told employees, "I announce I am a hacker and Uber has suffered a data breach." Jeff Chiu/Associated Press

By Kate Conger and Kevin Roose
Sept. 15, 2022

Steps followed by attackers

1. Social engineering campaign against Uber employees to get VPN access to *.corp.uber.com
2. Attacker found PowerShell scripts, one of which contained **hardcoded credentials** for an admin account
3. Using admin access, the attacker was able to log in and take over AWS, GCP, Google Drive, Slack workspace, ...

Source: <https://blog.gitguardian.com/uber-breach-2022/> (accessed on 22/9/2026)

2012 LinkedIn hack (exposed in 2016)

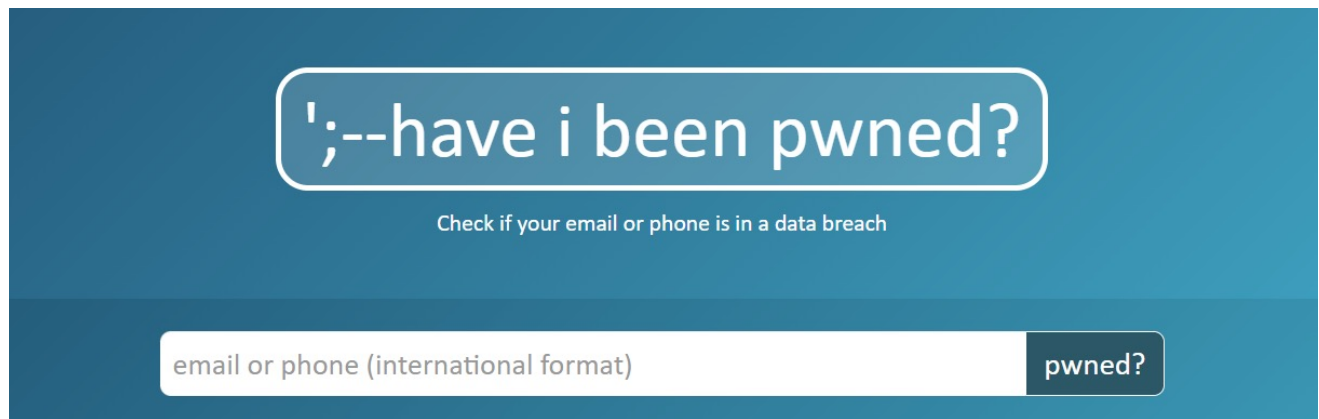
- 117 million user accounts hacked
- At first, theft of only 6 million user records was admitted
- LinkedIn only admitted the full extent after 4 years
- Records are being sold on the online black market
- Passwords were hashed using SHA-1
 - Companies have been advised not to use SHA-1 since 2005
 - No salt text was used to increase password decryption difficulty (same password translates into the same hash)



Source: https://en.wikipedia.org/wiki/2012_LinkedIn_hack (accessed on 22/9/2026)

Has your data been exposed?

<https://haveibeenpwned.com/>

The image shows a screenshot of the 'have i been pwned?' website. The background is a solid blue color. In the center, there is a white rounded rectangle containing the text 'have i been pwned?' in a white, lowercase, sans-serif font. Below this, in a smaller white font, is the text 'Check if your email or phone is in a data breach'. At the bottom of the screenshot, there is a white input field with the placeholder text 'email or phone (international format)'. To the right of the input field is a dark blue button with the text 'pwned?' in white.



<

Computer and Network Security - Part 1

 Visual settings

 Edit

When poll is active respond at

[PollEv.com/jfamaey](#)

Send [jfamaey](#) to +32 460 20 00 56



What was the most common password found in the 2012 LinkedIn hack?

 0

linkedin

123456789

qwerty

123456

password

Poll Title: Do not modify the notes in this section to avoid tampering with the Poll Everywhere activity.

More info at polleverywhere.com/support

What was the most common password found in the 2012 LinkedIn hack?

https://www.polleverywhere.com/multiple_choice_polls/FCpeC8ITLOqqofw?state=opened&flow=Default&onscreen=persist

1 Course goals

2 Practical course arrangements

3 Basic security concepts

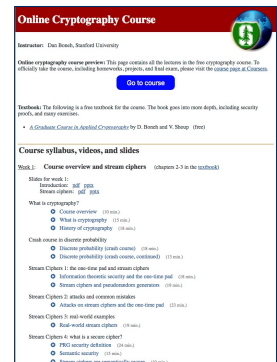
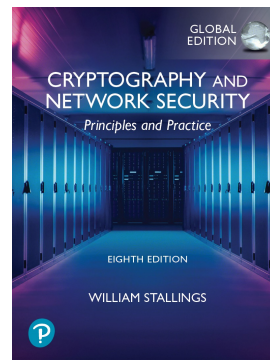
Theory

▪ Lectures

- 12 theory lectures (estimate)
- Wednesdays 8:30 – 10:30
- Room M.G.006
- Also streaming live via BBCollab and recordings available via Blackboard (only slides and voice, no camera)

▪ Study material

- Slides with notes (available via Blackboard)
- Optional in-depth material
 - W. Stallings, "Cryptography and Network Security: Principles and Practice, 8th Edition", Pearson, 2022.
<http://williamstallings.com/Cryptography/Crypto8e-Student/>
 - Stanford online cryptography course (videos available on Coursera) <https://crypto.stanford.edu/~dabo/courses/OnlineCrypto/>
 - D. Boneh and V. Shoup, "A graduate course in applied cryptography", version 0.6, <http://toc.cryptobook.us/>



Theory topics

Part	Topic
Part 1	Introduction
Part 2	Symmetric encryption
Part 3	Message integrity and hash functions
Part 4	Asymmetric encryption
Part 5	Key distribution, digital signatures, and authentication
Part 6	Network and web security

Calendar theory lectures

Week	Topic
1 (23/09/2026, 8h30-10h30)	Part 1 + Part 2 (History of Cryptography)
2 (30/09/2026, 8h30-10h30)	Part 2 (Stream Ciphers)
3 (07/10/2026, 8h30-10h30)	Part 2 (Block Ciphers)
4 (self-study, videos + slides)	Part 3 (Hashing Algorithms)
5 (21/10/2026, 8h30-10h30)	Part 3 (Message Authentication Codes + Secure Password Storage)
6 (28/10/2026, 8h30-10h30)	Part 4 (Asymmetric Encryption + RSA)
7 (04/11/2026, 8h30-10h30)	Part 4 (RSA + Elgamal Encryption + Digital Signatures)
8 (11/11/2026, 8h30-10h30)	No class (wapenstilstand)
9 (18/11/2026, 8h30-10h30)	Part 5 (Key Distribution)
10 (25/11/2026, 8h30-10h30)	Part 5 (User Management) + Part 6 (Wi-Fi Security)
11 (02/12/2026, 8h30-10h30)	Part 6 (IPSec + Transport Layer Security)
12 (9/12/2026, 8h30-10h30)	Part 6 (Application Layer Security) + Exam Info
13 (16/12/2026, 8h30-10h30)	Backup

Labs and hacking sessions

- **Lab sessions**

- Room M.G.025 (+ M.G.026)
- Thursday 16:00 – 18:00
- During weekly lab session, exercises are introduced, and you can ask questions
- Three **obligatory** hacking sessions

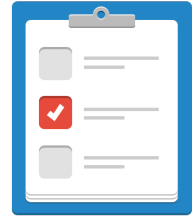
- **Practical**

- Programming exercises are not mandatory but **strongly** recommended as preparation for the hacking sessions
- **Hacking sessions are mandatory**
 - Done individually on lab computers
 - LLM/GenAI not allowed
 - Notes and prepared code is allowed
- Exercises can be performed on the lab computers
- Work on campus (during lab sessions) and/or at home

Calendar labs (tentative)

	Topic	Date
1	Introduction to the lab: History of Cryptography + Stream Ciphers	1/10
2	Block Ciphers	8/10
3	Hashing Algorithms	15/10
4	Message Authentication Codes + Secure Password Storage	22/10
	Hacking session 1 (Topics 1-4): Mandatory	29/10
5	Asymmetric Encryption + RSA	5/11
6	RSA + Elgamal Encryption + Digital Signatures	12/11
7	Key Distribution	19/11
	Hacking session 2 (Topics 5-7): Mandatory	26/11
8	User Management + Wi-Fi Security	3/12
9	IPSec + Transport Layer Security + Application Layer Security	10/12
	Hacking session 3 (All topics): Mandatory	17/12

Evaluation



- **40% on year work (8 points)**
 - 2 points for hacking session 1
 - 3 points each for hacking sessions 2 and 3
 - Cannot be redone during second examination period!
 - You must obtain at least 3/8 to be able to pass the course (otherwise your grades are rounded down to 8/20)
- **60% on theory exam (12 points)**
 - Written exam
 - Closed-book, but you can use a cheat sheet (1 sheet of A4 paper hand-written or printed recto-verso)
 - Example exam questions will be provided at the end of the semester
 - You must obtain at least 5/12 to be able to pass the course (otherwise your grades are rounded down to 8/20)
- (You must also obtain a total grade of 10/20 to pass the course)

Who is who?



Lecturer

- Prof. Jeroen Famaey (jeroen.famaey@uantwerpen.be)

Main contact for questions about theory and general course-related queries



Teaching assistants

- Douglas Agbeve (douglas.agbeve@uantwerpen.be)
- Wouter Lemoine (wouter.lemoine@uantwerpen.be)

Main contact for questions related to programming exercises, labs and hacking sessions

Where can you find us?

- Main office: The Beacon (Sint-Pietersvliet 7, 2000 Antwerp)
- After appointment: Campus Middelheim

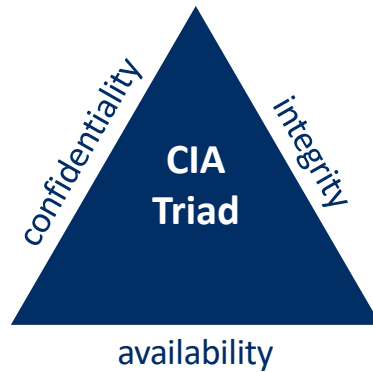
1 Course goals

2 Practical course arrangements

3 Basic security concepts

NIST computer security definition

“The protection afforded to an automated information system in order to attain the applicable objectives of preserving the **confidentiality, integrity and availability** of information system resources (includes hardware, software, firmware, information/data, and telecommunications)”



Confidentiality

- **Preserving the authorized restrictions on information access and disclosure**
- **Data confidentiality**
 - Information is not made available to unauthorized individuals
 - Mechanisms: encryption, authentication, access control, ...
- **Privacy**
 - Individuals control and influence what information about them is collected, stored, or disclosed (and to whom)
 - Mechanisms: GDPR, anonymization, VPN, ...

Student grade information is an asset whose confidentiality is considered to be highly important by students. In the United States, the release of such information is regulated by the Family Educational Rights and Privacy Act (FERPA). Grade information should only be available to students, their parents, and employees that require the information to do their job. Student enrollment information may have a moderate confidentiality rating. While still covered by FERPA, this information is seen by more people on a daily basis, is less likely to be targeted than grade information, and results in less damage if disclosed. Directory information, such as lists of students or faculty or departmental lists, may be assigned a low confidentiality rating or indeed no rating. This information is typically freely available to the public and published on a school's Web site.

Integrity

- **Guarding against improper information modification or destruction**
- **Data integrity**
 - Information is changed only in an authorized manner
 - Mechanisms: message authentication codes (MACs)
- **System integrity**
 - A system performs its intended function free of unauthorized manipulation
 - Mechanisms: digital signatures, intrusion detection, virus scanners

Several aspects of integrity are illustrated by the example of a hospital patient's allergy information stored in a database. The doctor should be able to trust that the information is correct and current. Now suppose that an employee (e.g., a nurse) who is authorized to view and update this information deliberately falsifies the data to cause harm to the hospital. The database needs to be restored to a trusted basis quickly, and it should be possible to trace the error back to the person responsible. Patient allergy information is an example of an asset with a high requirement for integrity. Inaccurate information could result in serious harm or death to a patient and expose the hospital to massive liability.

An example of an asset that may be assigned a moderate level of integrity requirement is a Web site that offers a forum to registered users to discuss some specific topic. Either a registered user or a hacker could falsify some entries or deface the Web site. If the forum exists only for the enjoyment of the users, brings in little or no advertising revenue, and is not used for something important such as research, then potential damage is not severe. The Web master may experience some data, financial, and time loss.

An example of a low integrity requirement is an anonymous online poll. Many Web sites, such as news organizations, offer these polls to their users with very few safeguards. However, the inaccuracy and unscientific nature of such polls is well understood.

Availability

- Ensuring timely and reliable access to and use of information with no denial of service to authorized users.
- Mechanisms: firewalls, virus scanners

The more critical a component or service, the higher is the level of availability required. Consider a system that provides authentication services for critical systems, applications, and devices. An interruption of service results in the inability for customers to access computing resources and staff to access the resources they need to perform critical tasks. The loss of the service translates into a large financial loss in lost employee productivity and potential customer loss.

An example of an asset that would typically be rated as having a moderate availability requirement is a public Web site for a university; the Web site provides information for current and prospective students and donors. Such a site is not a critical component of the university's information system, but its unavailability will cause some embarrassment.

An online telephone directory lookup application would be classified as a low availability requirement. Although the temporary loss of the application may be an annoyance, there are other ways to access the information, such as a hardcopy directory or the operator.

The OSI model security architecture

- **ITU-T Recommendation X.800: Security Architecture for OSI**

- Effectively assess the security needs of an organization and evaluate and choose various security products and policies.

- **Security attacks**

- Any action that compromises the security of owned information

- **Security mechanisms**

- A process that is designed to detect, prevent, or recover from attacks

- **Security services**

- A processing or communication service that enhances the security of data processing or transfer, using one or more security mechanisms

To assess effectively the security needs of an organization and to evaluate and choose various security products and policies, the manager responsible for security needs some systematic way of defining the requirements for security and characterizing the approaches to satisfying those requirements. This is difficult enough in a centralized data processing environment; with the use of local and wide area networks, the problems are compounded.

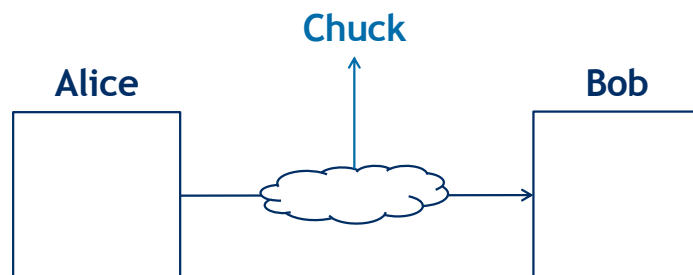
ITU-T Recommendation X.800, *Security Architecture for OSI*, defines such a systematic approach. The OSI security architecture is useful to managers as a way of organizing the task of providing security. Furthermore, because this architecture was developed as an international standard, computer and communications vendors have developed security features for their products and services that relate to this structured definition of services and mechanisms.

For our purposes, the OSI security architecture provides a useful, if abstract, overview of many security concepts. The OSI security architecture focuses on security attacks, mechanisms, and services. These can be defined briefly as

- **Security attack:** Any action that compromises the security of information owned by an organization.
- **Security mechanism:** A process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack.
- **Security service:** A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization. The services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the service.

Passive security attacks

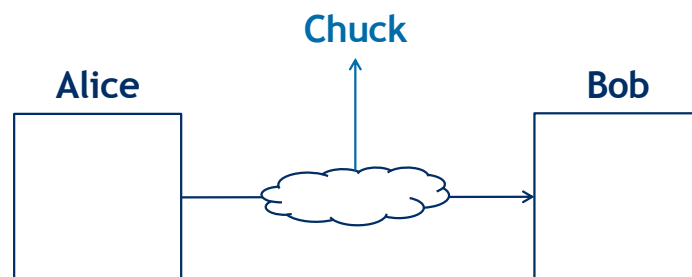
- Passively eavesdrop on, or monitor transmissions



Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions. The goal of the opponent is to obtain information that is being transmitted. Two types of passive attacks are the release of message contents and traffic analysis.

Types of passive security attacks

- **Release of message contents**
 - An opponent learns the contents of a message
- **Traffic analysis**
 - An opponent observes communication patterns, such as identity of hosts, frequency and length of messages, etc.



The **release of message contents** is easily understood. A telephone conversation, an electronic mail message, and a transferred file may contain sensitive or confidential information. We would like to prevent an opponent from learning the contents of these transmissions.

A second type of passive attack, **traffic analysis**, is subtler. Suppose that we had a way of masking the contents of messages or other information traffic so that opponents, even if they captured the message, could not extract the information from the message. The common technique for masking contents is encryption. If we had encryption protection in place, an opponent might still be able to observe the pattern of these messages. The opponent could determine the location and identity of communicating hosts and could observe the frequency and length of messages being exchanged. This information might be useful in guessing the nature of the communication that was taking place.



Poll Title: Do not modify the notes in this section to avoid tampering with the Poll Everywhere activity.

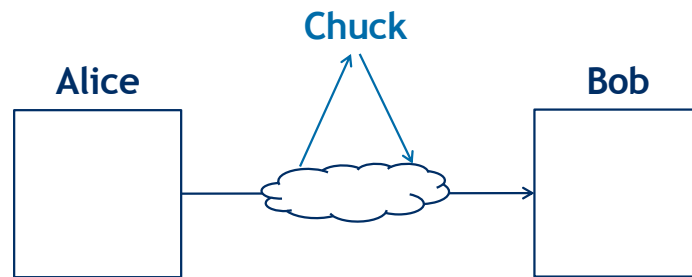
More info at polleverywhere.com/support

What is the best way to handle passive security attacks?

https://www.polleverywhere.com/multiple_choice_polls/KZT4WZ6qrEdROUz

Active security attacks

- Involves the modification of data or the creation of false data



Active attacks involve some modification of the data stream or the creation of a false stream and can be subdivided into four categories: masquerade, replay, modification of messages, and denial of service.

Types of active security attacks

- **Masquerade**
 - One entity pretends to be a different entity, usually combined with other attacks
- **Replay**
 - Passive capturing of data followed by subsequent retransmission to produce an unauthorized effect
- **Modification of messages**
 - Some portion of a legitimate message is altered, or messages are delayed or reordered to produce an unauthorized effect
- **Denial of service**
 - Prevents or inhibits the normal use or management of communication facilities by disrupting a network or part thereof

A **masquerade** takes place when one entity pretends to be a different entity. A masquerade attack usually includes one of the other forms of active attack. For example, authentication sequences can be captured and replayed after a valid authentication sequence has taken place, thus enabling an authorized entity with few privileges to obtain extra privileges by impersonating an entity that has those privileges.

Replay involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect.

Modification of messages simply means that some portion of a legitimate message is altered, or that messages are delayed or reordered, to produce an unauthorized effect. For example, a message meaning “Allow John Smith to read confidential file *accounts*” is modified to mean “Allow Fred Brown to read confidential file *accounts*.”

The **denial of service** prevents or inhibits the normal use or management of communications facilities. This attack may have a specific target; for example, an entity may suppress all messages directed to a particular destination (e.g., the security audit service). Another form of service denial is the disruption of an entire network, either by disabling the network or by overloading it with messages so as to degrade performance.



[<](#) Computer and Network Security - Part 1

 Visual settings

 Edit

When poll is active respond at

PollEv.com
/jfamaey

Send **jfamaey** to **+32 460 20 00 56**



In a grey hole attack a router discards a subset of messages instead of forwarding them, which type of active attack is this?

 0

Masquerade

Replay

Modification of messages

Denial of service

None of the above, it is a passive attack

Poll Title: Do not modify the notes in this section to avoid tampering with the Poll Everywhere activity.

More info at polleverywhere.com/support

In a grey hole attack a router discards a subset of messages instead of forwarding them, which type of active attack is this?

https://www.polleverywhere.com/multiple_choice_polls/5bl6oDCDedJslal

Active and passive attack mitigation

- **Passive attacks**

- Very hard to detect, so prevention (e.g., with encryption) is preferential

- **Active attacks**

- Very hard to prevent, due to the huge variety of potential vulnerabilities, so the goal is to detect and recover

Passive attacks are very difficult to detect, because they do not involve any alteration of the data. Typically, the message traffic is sent and received in an apparently normal fashion, and neither the sender nor receiver is aware that a third party has read the messages or observed the traffic pattern. However, it is feasible to prevent the success of these attacks, usually by means of encryption. Thus, the emphasis in dealing with passive attacks is on prevention rather than detection.

Active attacks present the opposite characteristics of passive attacks. Whereas passive attacks are difficult to detect, measures are available to prevent their success. On the other hand, it is quite difficult to prevent active attacks absolutely because of the wide variety of potential physical, software, and network vulnerabilities. Instead, the goal is to detect active attacks and to recover from any disruption or delays caused by them. If the detection has a deterrent effect, it may also contribute to prevention.

Security services

- **Authentication**
 - Assurance that the communicating entity is who it claims to be
- **Access control**
 - Prevention of unauthorized use of resources
- **Data confidentiality**
 - Protection of data from unauthorized disclosure
- **Data integrity**
 - Assurance that all data received is as sent by an authorized entity
- **Nonrepudiation**
 - Avoids denial of entities in communication of having taken part in it
- **Availability**
 - The system is usable upon demand by an authorized entity

X.800 defines a security service as a service that is provided by a protocol layer of communicating open systems and that ensures adequate security of the systems or of data transfers. Perhaps a clearer definition is found in RFC 4949, which provides the following definition: a processing or communication service that is provided by a system to give a specific kind of protection to system resources; security services implement security policies and are implemented by security mechanisms.

The **authentication service** is concerned with assuring that a communication is authentic. In the case of a single message, such as a warning or alarm signal, the function of the authentication service is to assure the recipient that the message is from the source that it claims to be from. In the case of an ongoing interaction, such as the connection of a terminal to a host, two aspects are involved. First, at the time of connection initiation, the service assures that the two entities are authentic, that is, that each is the entity that it claims to be. Second, the service must assure that the connection is not interfered with in such a way that a third party can masquerade as one of the two legitimate parties for the purposes of unauthorized transmission or reception.

In the context of network security, **access control** is the ability to limit and control the access to host systems and applications via communications links. To achieve this, each entity trying to gain access must first be identified, or authenticated, so

that access rights can be tailored to the individual.

Confidentiality is the protection of transmitted data from passive attacks. With respect to the content of a data transmission, several levels of protection can be identified. The broadest service protects all user data transmitted between two users over a period of time. For example, when a TCP connection is set up between two systems, this broad protection prevents the release of any user data transmitted over the TCP connection. Narrower forms of this service can also be defined, including the protection of a single message or even specific fields within a message. These refinements are less useful than the broad approach and may even be more complex and expensive to implement. The other aspect of confidentiality is the protection of traffic flow from analysis. This requires that an attacker not be able to observe the source and destination, frequency, length, or other characteristics of the traffic on a communications facility.

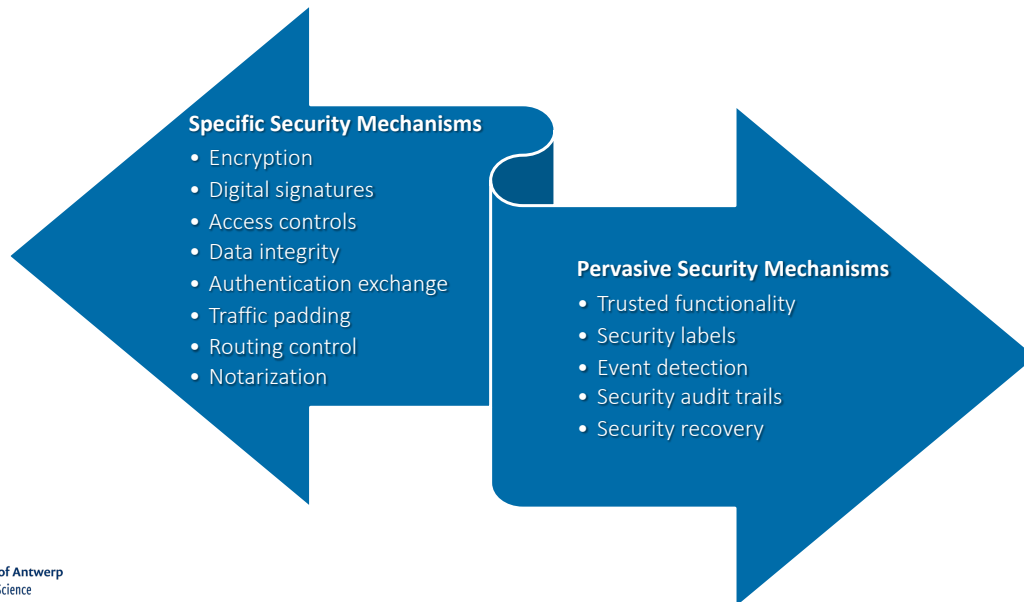
As with confidentiality, **integrity** can apply to a stream of messages, a single message, or selected fields within a message. Again, the most useful and straightforward approach is total stream protection. A connection-oriented integrity service, one that deals with a stream of messages, assures that messages are received as sent with no duplication, insertion, modification, reordering, or replays. The destruction of data is also covered under this service. Thus, the connection-oriented integrity service addresses both message stream modification and denial of service. On the other hand, a connectionless integrity service, one that deals with individual messages without regard to any larger context, generally provides protection against message modification only.

Nonrepudiation prevents either sender or receiver from denying a transmitted message. Thus, when a message is sent, the receiver can prove that the alleged sender in fact sent the message. Similarly, when a message is received, the sender can prove that the alleged receiver in fact received the message.

Both X.800 and RFC 4949 define **availability** to be the property of a system or a system resource being accessible and usable upon demand by an authorized system entity, according to performance specifications for the system (i.e., a system is available if it provides services according to the system design whenever users request them). A variety of attacks can result in the loss of or reduction in availability. Some of these attacks are amenable to automated countermeasures, such as authentication and encryption, whereas others require some sort of physical action to prevent or recover from loss of availability of elements of a distributed system.

Security mechanisms

A process that is designed to detect, prevent, or recover from attacks



The mechanisms are divided into those that are implemented in a specific protocol layer, such as TCP or an application-layer protocol, and those that are not specific to any particular protocol layer or security service. **Specific security mechanisms** may be incorporated into the appropriate protocol layer in order to provide some of the OSI security services. **Pervasive security mechanisms** are not specific to any particular OSI security service or protocol layer.

Specific security mechanisms:

- **Encipherment:** The use of mathematical algorithms to transform data into a form that is not readily intelligible. The transformation and subsequent recovery of the data depend on an algorithm and zero or more encryption keys.
- **Digital Signature:** Data appended to, or a cryptographic transformation of, a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery (e.g., by the recipient).
- **Access Control:** A variety of mechanisms that enforce access rights to resources.
- **Data Integrity:** A variety of mechanisms used to assure the integrity of a data unit or stream of data units.
- **Authentication Exchange:** A mechanism intended to ensure the identity of an entity by means of information exchange.
- **Traffic Padding:** The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.
- **Routing Control:** Enables selection of particular physically secure routes for

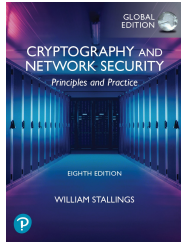
certain data and allows routing changes, especially when a breach of security is suspected.

- **Notarization:** The use of a trusted third party to assure certain properties of a data exchange.

Pervasive security mechanisms:

- **Trusted Functionality:** That which is perceived to be correct with respect to some criteria (e.g., as established by a security policy).
- **Security Label:** The marking bound to a resource (which may be a data unit) that names or designates the security attributes of that resource.
- **Event Detection:** Detection of security-relevant events.
- **Security Audit Trail:** Data collected and potentially used to facilitate a security audit, which is an independent review and examination of system records and activities.
- **Security Recovery:** Deals with requests from mechanisms, such as event handling and management functions, and takes recovery actions.

Further reading material



Chapter 1: Computer and Network Security Concepts



Week 1: What is cryptography?

- Course overview
- What is cryptography